

GOVSECURE | GOVERNANCE WORKFLOW AND ADD-ON TOOL

3rd-Party AI Vendor Risk Review

Structured due diligence and decision workbook for reviewing AI vendors, copilots, embedded AI features, and AI-enabled SaaS before approval.

Prepared For	{{COMPANY_NAME}}
Version / Effective Date	v1.0 {{EFFECTIVE_DATE}}
Primary Use	Pre-procurement, renewal, major feature enablement, or control revalidation

Purpose Use this workbook to evaluate third-party AI products and AI-enabled vendor features with a standard, defensible review method. It is built for SMBs that buy AI more often than they build it, and need practical evidence before saying yes.

This workbook should be retained as the internal review record. The decision summary page can be shared with procurement, leadership, security, legal, or business owners as needed.

1. Review Overview

This review is designed to answer a simple question: can this vendor be trusted to support the intended AI use case at an acceptable level of risk? It gives the organization a repeatable structure for assessing security, privacy, legal, operational, and AI-specific concerns before approval.

What it does	Primary user	Output produced	Best use case
Captures vendor facts, risks, evidence, and a final decision in one review record.	AI governance lead, security, privacy, legal, procurement, or business owner.	A documented risk review, remediation list, and approval decision.	New AI procurement, contract renewal, embedded AI feature activation, or control refresh.

2. Standard Decision Outcomes

- Approve - vendor is acceptable for the reviewed use case under normal operating controls.

- Approve with conditions - vendor may be used only after defined remediation items, contract terms, configuration changes, or internal controls are completed.
- Defer - review cannot close because critical evidence is missing or the scope is still changing.
- Reject - vendor risk is too high, controls are insufficient, or the use case is not acceptable.

Practical rule Do not approve a vendor just because a business team already likes the demo. Demos are theater. Due diligence is rent.

3. Vendor Profile and Engagement Context

Complete this profile before scoring the review. It defines what is being bought, who will use it, and why the vendor matters.

Vendor name	{{VENDOR_NAME}}
Product / service name	{{PRODUCT_NAME}}
Business owner	{{BUSINESS_OWNER}}
Reviewer / document owner	{{DOCUMENT_OWNER}}
Intended use case	{{USE_CASE_DESCRIPTION}}
User population	{{USER_POPULATION}}
Customer-facing or internal	{{INTERNAL_OR_EXTERNAL_USE}}
Data categories involved	{{DATA_CATEGORIES}}
Deployment / connection model	{{DEPLOYMENT_MODEL_AND_INTEGRATIONS}}
Contract stage	{{NEW_PURCHASE_OR_RENEWAL}}
Renewal or go-live target date	{{TARGET_DATE}}
Supporting documents / links	{{LINKS_TO_MSA_DPA_SOC2_SECURITY_DOCS}}

4. Inherent Risk Screening

Rate the inherent exposure before considering controls. This determines whether the vendor can follow a lightweight review or requires escalation.

Risk factor	What to look for	Rating	Reviewer notes
Sensitive data exposure	Will the vendor process confidential, customer, employee, regulated, source code, or high-value data?	[L/M/H]	{{NOTES}}
Decision impact	Will outputs influence customer, employee, financial, safety, legal, or operational decisions?	[L/M/H]	{{NOTES}}
External exposure	Is the tool customer-facing, public-facing, or directly visible outside the company?	[L/M/H]	{{NOTES}}
Autonomy level	Does the vendor automate actions, trigger workflows, or make decisions without strong human review?	[L/M/H]	{{NOTES}}
Integration depth	Will it connect to core systems, file stores, email, identity, CRM, ERP, or code repositories?	[L/M/H]	{{NOTES}}
Regulatory or contract sensitivity	Does the use case touch privacy, industry regulations, customer obligations, or IP risk?	[L/M/H]	{{NOTES}}

5. Required Evidence Request

- Security or trust documentation (for example SOC 2, ISO 27001, penetration summary, or equivalent assurance).
- Privacy or data processing terms, including DPA, subprocessors, retention terms, and geographic processing information.
- Product architecture or security overview showing where data is stored, processed, and connected.

- AI-specific documentation covering model use, training on customer data, controls, explainability, and limitations.
- Standard contract, MSA, order form, and any AI-specific terms or feature annexes.
- Incident response, business continuity, and support commitments where relevant.

Escalation trigger If the vendor refuses to answer basic data handling questions, will not explain training use of customer data, or provides security language that sounds like a horoscope, escalate before anything gets signed.

6. Detailed Review Domains

Use the following worksheets to record the vendor response, evidence received, and reviewer position for each control area. Suggested ratings: Acceptable, Needs Follow-up, or Material Concern.

6.1 Security and Access Controls

Control area	Vendor response or evidence	Rating	Reviewer notes / action
Identity and access	Does the product support SSO, MFA, role-based access, and admin segregation? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}
Encryption and transport	Is data encrypted in transit and at rest, and is key management described? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}
Tenant isolation	How does the vendor separate customer environments, data, and admin access? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}
Logging and monitoring	Are admin actions, user activity, exports, and security events logged and reviewable? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}

Control area	Vendor response or evidence	Rating	Reviewer notes / action
Vulnerability management	Does the vendor patch, test, and monitor the product with a defined security program? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}

6.2 Data Governance and Privacy

Control area	Vendor response or evidence	Rating	Reviewer notes / action
Data use and retention	What customer data is collected, how long is it retained, and can retention be controlled? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}
Training on customer data	Does the vendor use prompts, uploads, outputs, or telemetry to train models; can this be disabled? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}
Subprocessors and transfers	Are subprocessors disclosed and are cross-border processing and transfer protections clear? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}
Deletion and portability	Can data be deleted on request and exported at termination in a usable format? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}
Sensitive data controls	What restrictions or protections exist for regulated, confidential, or customer-sensitive information? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}

6.3 AI-Specific Governance and Model Controls

Control area	Vendor response or evidence	Rating	Reviewer notes / action
Model transparency	What model or models are used, and is the vendor clear about limitations and dependencies? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}
Output quality and oversight	What safeguards exist for hallucination, unsafe output, poor recommendations, or incorrect automation? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}
Human review support	Can workflows require human approval or verification before material actions are taken? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}
Feature change management	How are new AI features introduced, communicated, and made controllable by the customer? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}
Testing and validation	Does the vendor test model behavior, monitor drift or abuse, and document major known failure modes? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}

6.4 Legal, Contract, and Compliance Position

Control area	Vendor response or evidence	Rating	Reviewer notes / action
Contract clarity	Do the contract and terms clearly address data use, IP, confidentiality, and security obligations? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}
Regulatory support	Can the vendor support relevant privacy, sector, or customer compliance obligations? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}
IP and output rights	Are ownership and reuse rights for prompts, outputs, and customer content clearly addressed? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}
Audit and notification	Are incident notification, audit support, and cooperation terms commercially usable? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}
Liability and commercial friction	Are caps, exclusions, and risk allocation tolerable for the intended use case? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}

6.5 Operational Resilience and Exit Readiness

Control area	Vendor response or evidence	Rating	Reviewer notes / action
Availability and support	Are uptime expectations, support channels, response times, and escalation paths credible? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}

Control area	Vendor response or evidence	Rating	Reviewer notes / action
Incident response	Does the vendor have a mature process for investigation, containment, and notification? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}
Business continuity	Are resilience, backup, recovery, and continuity practices described well enough for the risk level? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}
Roadmap dependency risk	Is the use case overly dependent on features still in beta, roadmap promises, or unstable service terms? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}
Exit strategy	Can the company turn off, replace, or exit the vendor without getting handcuffed to its data or workflow? {{VENDOR_RESPONSE}}	[A/F/C]	{{REVIEWER_NOTE}}

7. Risk Findings and Remediation Plan

Summarize only the findings that matter. Nobody wants a museum of observations. Focus on the conditions that drive the decision.

Finding / gap	Severity	Required action	Owner	Due date
{{GAP}}	{{L/M/H}}	{{ACTION}}	{{OWNER}}	{{DATE}}
{{GAP}}	{{L/M/H}}	{{ACTION}}	{{OWNER}}	{{DATE}}
{{GAP}}	{{L/M/H}}	{{ACTION}}	{{OWNER}}	{{DATE}}
{{GAP}}	{{L/M/H}}	{{ACTION}}	{{OWNER}}	{{DATE}}

8. Final Decision Summary

Final recommendation	{{RECOMMENDATION}}
Approved use conditions	{{CONDITIONS}}
Residual risk statement	{{RESIDUAL_RISK}}
Review next date	{{NEXT_REVIEW}}

9. Approval Record

Prepared by	{{DOCUMENT_OWNER}}
Business owner sign-off	{{OWNER_SIGNOFF}}
Security / privacy / legal review	{{REVIEWERS}}
Approver	{{APPROVER}}
Issue date / next review	{{ISSUE_NEXT_REVIEW}}

10. Quick Implementation Checklist

- Match the review depth to the real use case. A note-taking bot is not a decision engine; do not treat them the same.
- Make sure procurement, legal, security, and the business owner see the same final recommendation, not four contradictory folk tales.
- Tie approved vendors back to the AI use case registry so vendor review and use case approval stay connected.
- Re-run the review when the vendor adds major AI features, changes data use terms, or expands into higher-risk use cases.